IT• Akademie
Dr. Heuer

Zertifikate

Ziele der sicheren Kommunikation

- Vertraulichkeit
  - Daten sollen nicht von anderen gelesen werden
- Integrität
  - Daten sollen nicht auf dem Übertragungsweg verfälscht werden
- Authentizität
  - Identität ist gesichert
  - Nachricht stammt tatsächlich vom Absender

Symmetrische Verschlüsselung

- Zum Verschlüsseln und entschlüsseln wird der gleiche Schlüssel verwendet
- Schlüssel muss auf sicherem Weg verteilt werden
- Wenn mehrere Personen den Schlüssel benötigen, steigt die Wahrscheinlichkeit, dass Schlüssel entdeckt wird

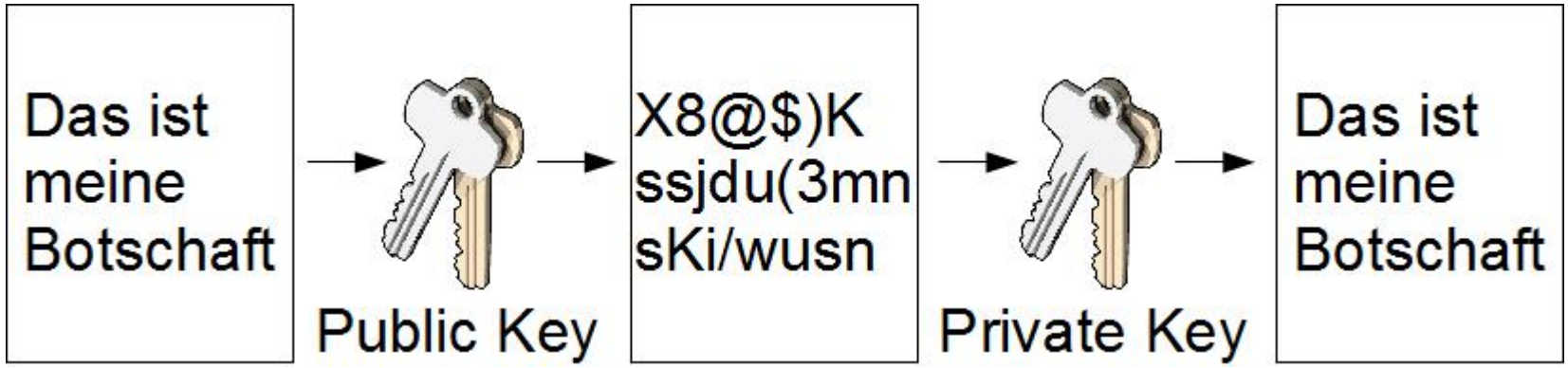


Symmetrische Algorithmen

- Data Encryption Standard (DES)
  - 56-Bit Schlüssel
  - ANSI Standard
- Triple DES (3DES)
  - DES wird dreimal angewendet
  - 168-Bit Schlüssel
  - Aufwendig
- Advanced Encryption Standard (AES)
  - Nachfolger von DES
  - Schlüssellängen von 128-256 Bit
- RC4
  - variable Schlüssellänge für Datenströme (128, 192 oder 256 Bit)

Asymmetrische Verschlüsselung

- Zum Verschlüsseln wird ein anderer Schlüssel als zum Entschlüsseln verwendet
- Public Key
  - Verschlüsselung
  - Öffentlich zugänglich
- Private Key
  - Entschlüsselung
  - Muss unbedingt geheim gehalten werden



Asymmetrische Verschlüsselung

1. Der Absender besorgt sich den **öffentlichen** Schlüssel des **Empfängers**

2. Klartext wird mit dem **öffentlichen** Schlüssel des **Empfängers** verschlüsselt

3. Der verschlüsselte Text wird an den Empfänger geschickt

4. Der **Empfänger entschlüsselt** den verschlüsselten Text mit **seinem privaten** Schlüssel

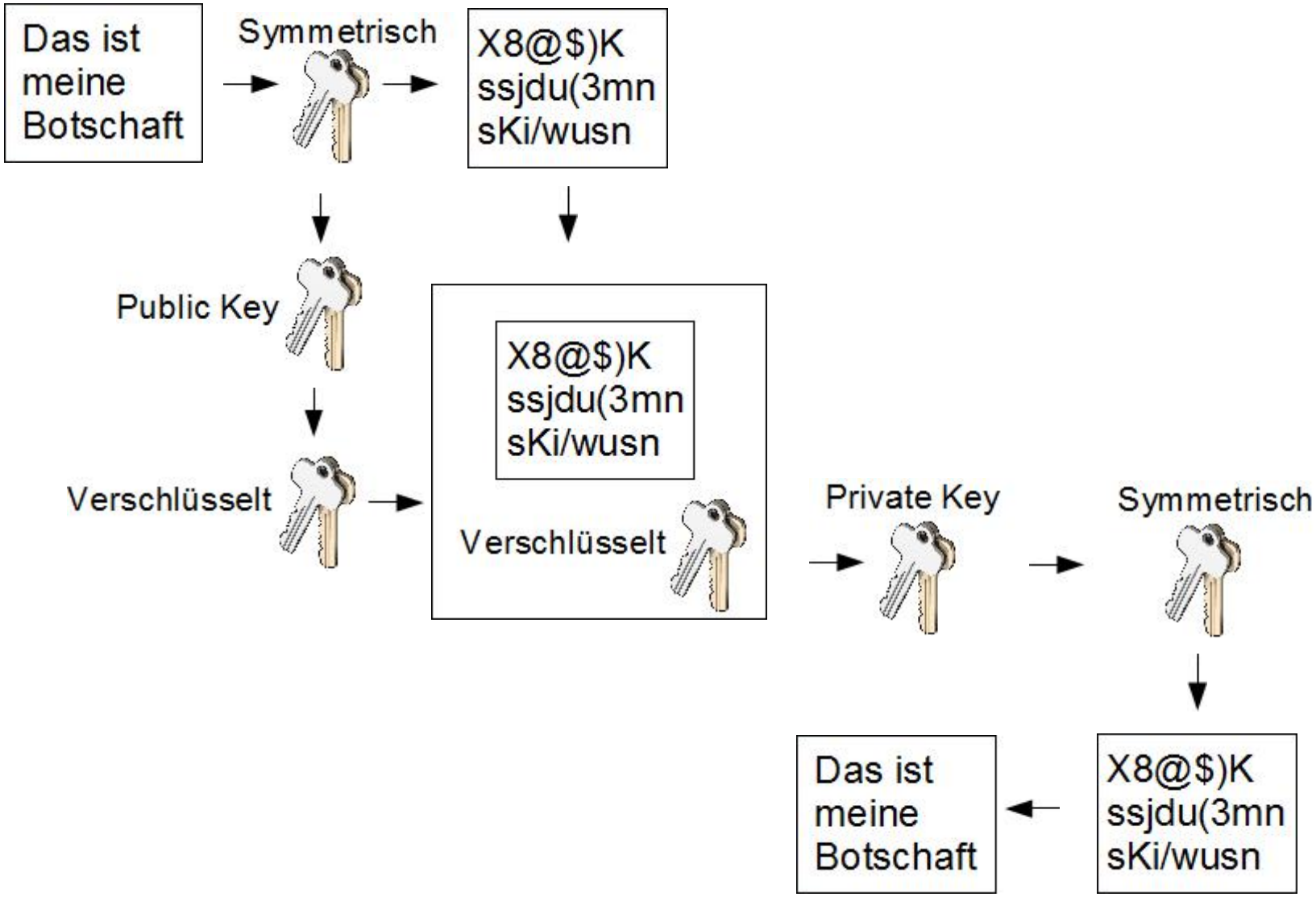
Asymmetrische Algorithmen

- Rivest Shamir Adleman (RSA)
  - Verschlüsselung und Signatur von Daten
  - Schlüssellängen bis 4096 Bit möglich
- Digital Signature Algorithm (DSA)
  - Dieser Algorithmus eignet sich nur für die Signatur von Daten und nicht zur Verschlüsselung
- Diffie-Hellman Schlüsselvereinbarung
  - Verfahren einen gemeinsamen privaten Schlüssel zu generieren
  - Bei IPSec verwendet

Vor- und Nachteile

- Symmetrische Verschlüsselung
  - Vorteil:
    - *sehr effizient durchführbar*
  - Nachteil:
    - *Schlüsselaustausch riskant*
- Asymmetrische Verschlüsselung
  - Vorteil:
    - *Kein Schlüsselaustausch nötig*
  - Nachteil:
    - *sehr ineffizient (mindestens um den Faktor 1000 langsamer!)*
- Lösung
  - Kombination beider Verfahren

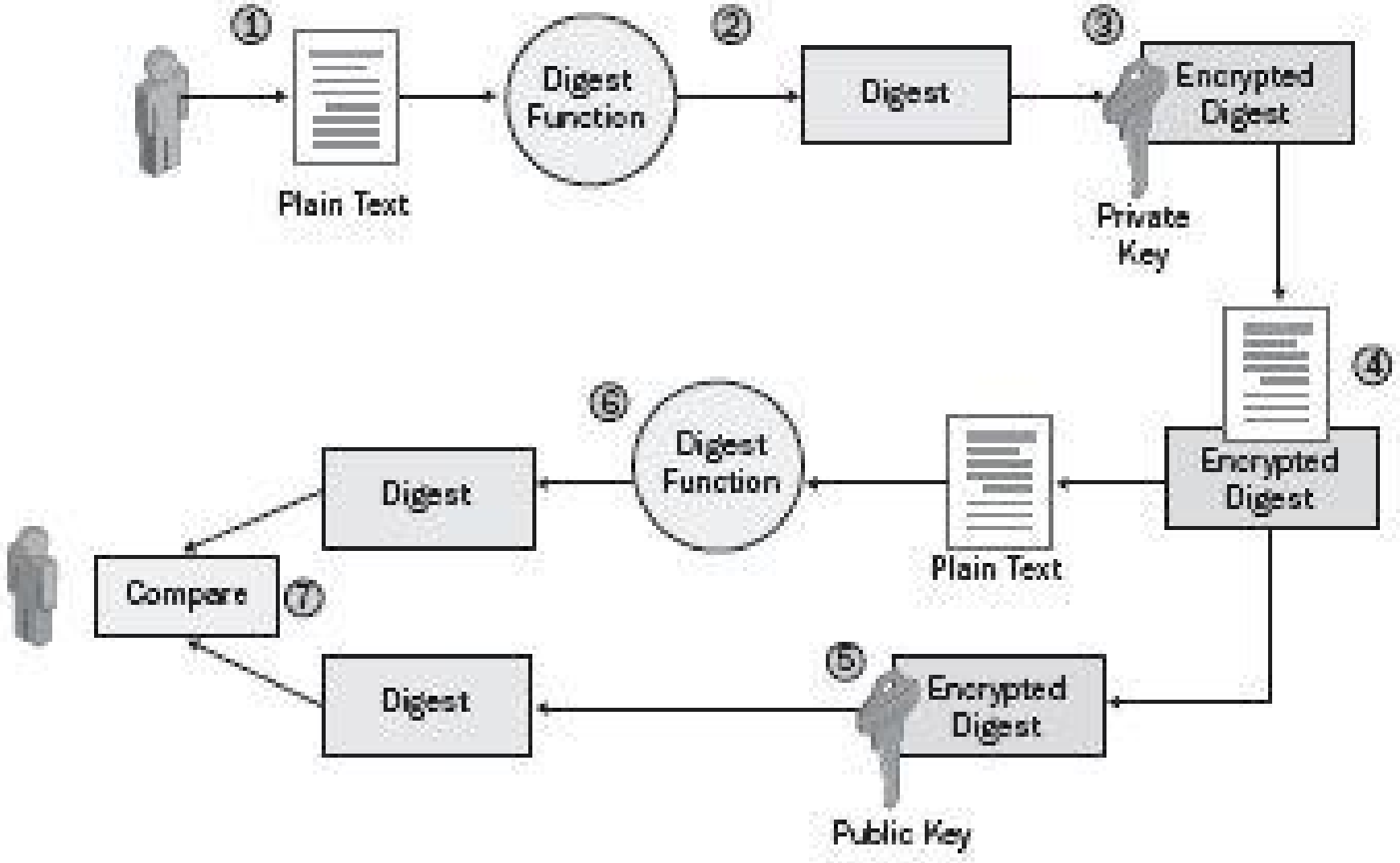
Kombination aus beiden Verfahren



Digitale Signatur

- Sichern die Integrität der Daten
- Aus Botschaft wird mit Hilfe einer mathematischen Funktion ein Hashwert gebildet
  - Auch Nachrichtenhash oder Digest genannt
  - Ändert sich die Botschaft wird der Hashwert ungültig
- Hashfunktionen
  - Message Digest 5 (MD5)
    - *128 Bit*
  - Secure Hash Algorithm (SHA1)
    - *160 Bit*
    - *Gilt als sicherer*

Digitale Signatur



Digitale Signatur

1. Der **Ersteller** erzeugt eine Datendatei im Klartext
2. Die Software des Erstellers berechnet aus der Klartextnachricht mit Hilfe eine Hashalgorithmus einen Nachrichtenhash (message digest).
3. Der **Nachrichtenhash** wird mit dem **privaten** Schlüssel des **Erstellers verschlüsselt**
4. Die Klartextnachricht und der verschlüsselte Nachrichtenhash werden an den Empfänger geschickt
5. Der **Empfänger entschlüsselt** den verschlüsselten **Nachrichtenhash** mit dem **öffentlichen** Schlüssel des **Absenders**. Er kann mit den signierten Daten verschickt werden. (Sicherheitsrisiko!!!)
6. Der **Empfänger** berechnet aus der Klartextnachricht einen eigenen **Hashwert**
7. Die beiden Hashwerte werden verglichen. Weichen sie voneinander ab, wurde die Nachricht verändert

Public Key Infrastructure (PKI)

- Digitale Zertifikate
  - Digital signierte elektronische Daten, die sich zum Nachweis der Echtheit von Objekten verwenden lassen
- Zertifizierungsstelle (Certification Authority, CA)
  - Organisation, welche das CA-Zertifikat bereitstellt und die Signatur von Zertifikatsanträgen übernimmt
- Zertifikatsperrliste (Certificate Revocation List, CRL)
  - Eine Liste mit Zertifikaten, die vor Ablauf der Gültigkeit zurückgezogen wurden, z.B. weil das Schlüsselmaterial kompromittiert wurde

Inhalt eines Zertifikates

- E-Mailadresse des Benutzers
- Den Benutzerprinzipalnamen (UPN)
- Den Hostnamen des Computers
- Den öffentlichen Schlüssel aus dem zum Zertifikat gehörigen Schlüsselpaar
- Version (X.509 v1 | 2 | 3 Standard)
- Seriennummer des Zertifikats
- Den Namen der ausstellenden Zertifizierungsstelle
- Namen des Verschlüsselungsalgorithmus
- Gültigkeitszeitraum
- Zweck des Zertifikates (z.B. EFS, Anmeldung)

Aufgaben einer Zertifizierungsstelle

- Überprüfen der Identität der Antragsteller
  - Active Directory
  - Prüfung des Ausweises
- (Generieren eines Schlüsselpaares)
- Ausstellung und Signierung von Zertifikaten
- Verwalten von Zertifikatsperrungen
  - Basissperrliste
    - *Enthält alle gesperrten Zertifikate*
  - Deltasperrliste
    - *Enthält Zertifikate, die seit der letzten Veröffentlichung der Basissperrliste gesperrt wurden*
- Veröffentlichen von Richtlinien
  - z.B. Sicherung der CA, Prüfung der Identität

Installation einer Zertifizierungsstelle

- Domänen- oder Organisationsadmin
- Active Directory Certificate Services
  - Rechner kann nicht mehr umbenannt werden
- Zertifizierungsstellentyp auswählen
  - Stammzertifizierungsstelle des Unternehmens
  - Untergeordnete des Unternehmens
  - Eigenständige Stammzertifizierungsstelle
  - Eigenständige untergeordnete Zertifizierungsstelle
- Schlüsselpaar generieren

Installation einer Zertifizierungsstelle

- Kryptographiedienstanbieter und Hashalgorithmus
- Name und Gültigkeitsdauer
- Pfade für Zertifikate und Protokolle
- Zertifikat einer übergeordneten CA anfordern (Optional)

Zertifikatvorlagen

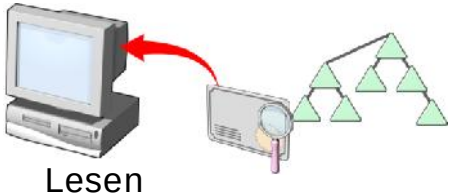
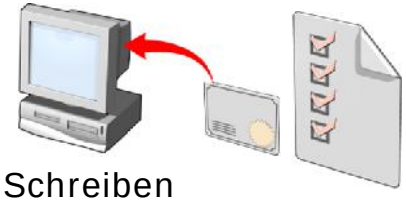
- Nur in Unternehmenszertifizierungsstellen
- Definieren:
  - Format und Inhalt eines Zertifikats basierend auf seinem vorgesehenen Zweck
  - Den Prozess zum Erstellen und Einreichen einer gültigen Zertifikatanforderung
  - Sicherheitsprinzipale, die das Zertifikat lesen und registrieren bzw. sich für das Zertifikat automatisch registrieren dürfen
  - Berechtigungen zum Lesen, Registrieren, automatischen Registrieren und Ändern von Zertifikatvorlagen mithilfe von DACLs

Kategorien von Zertifikatsvorlagen

IT-Akademie Dr. Heuer

Kategorie	Eine Funktion	Mehrere Funktionen
 **Benutzer**	• Basis-EFS • Authentifizierte Sitzung • Smartcard-Anmeldung	• Administrator • Benutzer • Smartcard-Benutzer
 **Computer**	• Webserver • IPSec	• Computer • Domänen-controller

Berechtigungen für Zertifikatvorlagen

Berechtigung	Beschreibung
 Vollzugriff	Ermöglicht einem Sicherheitsprinzipal das Ändern aller Attribute
 Lesen	Ermöglicht einem Sicherheitsprinzipal die Suche nach dem Zertifikat in Active Directory bei der Registrierung
 Schreiben	Ermöglicht einem Sicherheitsprinzipal das Ändern aller Attribute außer Berechtigungen
 Registrieren	Ermöglicht einem Sicherheitsprinzipal das Registrieren für ein Zertifikat basierend auf der Zertifikatvorlage
 Automatisch registrieren	Ermöglicht einem Sicherheitsprinzipal, über die automatische Registrierung ein Zertifikat zu erhalten

Automatische Registrierung

- Clients über GPO konfigurieren
  - Computerkonfiguration\Richtlinien\Windows-Einstellungen\Sicherheitseinstellungen\ Richtlinien für öffentliche Schlüssel
    - *Zertifikatdienstclient – Automatische Registrierung aktivieren*
      - *Abgelaufene Zertifikate erneuern, ausstehende Zertifikate aktualisieren und gesperrte Zertifikate entfernen*
      - *Zertifikate, die Zertifikatvorlagen verwenden, aktualisieren*
  - Auch in Benutzerkonfiguration konfigurierbar
- Server manuell konfigurieren (standardmäßig konfiguriert)
  - Eigenschaften der CA -> Richtlinienmodul -> Eigenschaften -> Den Einstellungen der Zertifikatvorlage folgen, falls zutreffend. Zertifikat ansonsten automatisch ausstellen